

API Endpoints Specifikation: Content Slides

Backend-mappning för Onboarding-flödet (med Sidebar)

Celestial AB

25 oktober 2025

Innehåll

1	Introduktion	2
1.1	Dokumentstruktur	2
1.2	Teknisk arkitektur	2
2	SEKTION 1: Uppdragsval och introduktion	4
2.1	Content Slide: Välkommen – Uppdragets art	4
2.2	API-endpoints för Uppdragsval och introduktion	4
2.2.1	POST /api/onboarding/uppdrag	4
3	Sektion 2A: Riskfrågor – Steg 1	7
3.1	API-endpoints Sammanfattning (Våra endpoints)	7
3.2	Översikt - När anropas våra endpoints	7
3.3	Externa API-endpoints Sammanfattning	8
3.4	Översikt - Varför behövs externa endpoints	8
3.5	Endpoint 1: POST /api/onboarding/{onboardingId}/riskfragor/steg1	8
3.5.1	Beskrivning	8
3.5.2	Request	8
3.5.3	Response 200 OK - Inga riskflaggor	9
3.5.4	Response 200 OK - Riskflaggor aktiva	11
3.5.5	Response 200 OK - VH Mismatch Detected (Warning)	11
3.5.6	Response 200 OK - Med Custom Config	12
3.5.7	Response 400 Bad Request	13
3.5.8	Response 403 Forbidden	14
3.5.9	Response 404 Not Found	14
3.5.10	Implementation Notes	14
3.6	Extern Endpoint 1: POST /organisationer (Bolagsverket)	18
3.6.1	Beskrivning	18
3.6.2	Request	18
3.6.3	Response 200 OK	18
3.6.4	Implementation Notes för Response	19
3.7	Extern Endpoint 2: POST /navet/spar/personnummer (Skatteverket SPAR)	19
3.7.1	Beskrivning	19
3.7.2	Request	19
3.7.3	Response 200 OK	20

3.7.4	Implementation Notes för Response	20
3.8	Extern Endpoint 3: GET /se/company/beneficial-owners/2.1/{orgNr} (Roaring)	20
3.8.1	Beskrivning	20
3.8.2	Request	20
3.8.3	Response 200 OK - Med VH >25%	21
3.8.4	Response 200 OK - Tom array (ingen >25%)	21
3.8.5	Implementation Notes för Response	21
3.9	Extern Endpoint 4: GET /se/company/alternative-beneficial-owner/1.0/{orgNr} (Roaring)	22
3.9.1	Beskrivning	22
3.9.2	Request	22
3.9.3	Response 200 OK	22
3.9.4	Implementation Notes för Response	22
3.10	Extern Endpoint 5: GET /se/pep/1.0/{personnr} (Roaring)	23
3.10.1	Beskrivning	23
3.10.2	Request	23
3.10.3	Response 200 OK - Är PEP	23
3.10.4	Response 200 OK - Inte PEP	23
3.10.5	Implementation Notes för Response	23
3.11	Extern Endpoint 6: GET /se/sanctions/1.0/{personnr} (Roaring)	24
3.11.1	Beskrivning	24
3.11.2	Request	24
3.11.3	Response 200 OK - Är sanktionerad	24
3.11.4	Response 200 OK - Inte sanktionerad	24
3.11.5	Implementation Notes för Response	24
3.12	Extern Endpoint 7: GET /se/businessprohibition/1.0/person/{personnr} (Roaring)	25
3.12.1	Beskrivning	25
3.12.2	Request	25
3.12.3	Response 200 OK - Har näringsförbud	25
3.12.4	Response 200 OK - Inget näringsförbud	25
3.12.5	Implementation Notes för Response	25
3.13	Backend Persistent Lagring	26
3.14	Frontend Datalagring i Browser	27
3.14.1	localStorage	27
3.14.2	Cookies	28
3.15	Backend - Behandlingshistorik och GDPR	28
3.15.1	Loggade händelser	28
3.15.2	CSV-filer (Primär databasimplementation)	29
3.16	Databastabeller (Framtida PostgreSQL-optimering)	30
3.17	Custom Wizard Config (Valfri anpassning via Inställningar)	30
3.17.1	Översikt	30
3.17.2	Upload Endpoint	30
3.17.3	Config.json Structure	31
3.17.4	Regler för Custom Config	32
3.17.5	Frontend Rendering	32
3.18	Sammanfattning (Prosaisk beskrivning)	33

3.18.1	Scenario 1: Första gången - Inga riskflaggor	33
3.18.2	Scenario 2: Triggers aktiverade (högre risk)	37
3.18.3	Scenario 3: Validering misslyckas - 403 Forbidden	38
3.18.4	Teknisk sammanfattning	38
4	SEKTION 2B: Riskfrågor – Steg 2 (Fördjupade frågor)	40
4.0.1	POST /api/onboarding/{onboardingId}/riskfrågor/steg2	40
5	SEKTION 3: Identitetskontroll	45
6	SEKTION 4: Jämförelse mot externa register	45
7	SEKTION 5: Företagsdokumentation	45
8	SEKTION 6: Ekonomisk analys	45
9	SEKTION 7: Djupgranskning och avtal	45

1 Introduktion

Detta dokument beskriver **alla API endpoints** som behövs för onboarding-slidesen (content slides med sidebar) enligt `Onboardin_app_ny.tex`.

Dessa slides visas **efter inloggning** och utgör själva onboarding-processen där användaren:

- Väljer uppdragets art (vilka tjänster som behövs)
- Besvarar riskfrågor (PTL-krav)
- Genomgår identitetskontroll
- Jämförs mot Bolagsverket/Roaring.io
- Laddar upp företagsdokumentation
- Får ekonomisk analys och riskbedömning
- Signerar avtal med BankID

1.1 Dokumentstruktur

Dokumentet följer samma struktur som `Onboardin_app_ny.tex` med sections och sub-sections:

- **Sektion 1:** Uppdragsval och introduktion
- **Sektion 2:** Riskbedömning (Steg 1 + Steg 2 fördjupning)
- **Sektion 3:** Identitetskontroll
- **Sektion 4:** Jämförelse mot externa register
- **Sektion 5:** Företagsdokumentation
- **Sektion 6:** Ekonomisk analys (SIE + Bankkonto)
- **Sektion 7:** Djupgranskning och avtal

För varje slide/steg dokumenteras:

- Vilka API endpoints som behövs
- HTTP-metod (GET, POST, PUT, DELETE)
- Request-format (JSON schema, multipart/form-data för filer)
- Response-format (success och error cases)
- Affärslogik och valideringar
- Externa integrationer (Bolagsverket, Skatteverket, Roaring.io, BankID, etc.)
- Databastabeller som påverkas
- Riskindikatorer och flaggor

1.2 Teknisk arkitektur

- **Databas:** CSV-filer under utveckling, PostgreSQL som slutoptimering (använder UUID för process-ID)
- **Externa API:er:** Bolagsverket, Skatteverket SPAR, Roaring.io, BankID
- **AI-analys:** Hugging Face (microsoft/layoutlmv3-large) via Celery background tasks
- **Fillagring:** S3/MinIO för uppladdade dokument (SIE, PDF, etc.)
- **Autentisering:** JWT tokens med `user_id`, varje onboarding-process identifieras med UUID

VIKTIGT om databasval: Hela applikationen byggs FÖRST med CSV-filer för ALL databashantering (onboarding_processes.csv, external_api_responses.csv, event_log.csv, etc.). PostgreSQL SQL införs som slutoptimering ENDAST efter att hela applikationen fungerar felfritt. Detta för att undvika race conditions och skrivfel vid flera samtidiga användare. CSV-first approach = snabbare utveckling, enklare debugging.

2 SEKTION 1: Uppdragsval och introduktion

2.1 Content Slide: Välkommen – Uppdragets art

React route: /inledning

Beamer label: intro

Sidebar: Ja (första slide med sidebar)

Beskrivning:

Användaren väljer vilka tjänster de är intresserade av (löpande bokföring, årsbokslut, deklarationer, etc.). Detta är första steget i onboarding och sätter tonen för hela processen – kunden i centrum, myndighetskrav sekundärt.

2.2 API-endpoints för Uppdragsval och introduktion

2.2.1 POST /api/onboarding/uppdrag

Beskrivning:

Skapar en ny onboarding-process, sparar kundens valda tjänster och beräknar uppskattad kostnad baserat på vald tjänstekombination. Returnerar ett UUID som används för alla efterföljande API-anrop i denna onboarding-process.

Request Headers:

```
1 {
2   "Authorization": "Bearer_<access_token>",
3   "Content-Type": "application/json"
4 }
```

Request Body:

```
1 {
2   "lopandeBokforing": true,
3   "arsbokslut": true,
4   "deklarationer": false,
5   "loneadministration": false,
6   "ekonomiskRadgivning": true,
7   "foretagsregistrering": false,
8   "finansiellRapportering": false,
9   "foretagsforsaljning": false,
10  "annat": "Succession_till_nasta_generation"
11 }
```

Response (200 OK):

```
1 {
2   "success": true,
3   "onboardingId": "a7f3c8e2-4b1d-4e9a-8c3f-1a2b3c4d5e6f",
4   "uppskattadKostnad": "15000_kr/år",
5   "antalTjanster": 3,
6   "riskIndikator": "low",
7   "message": "Onboarding-process_skapad",
8   "nextStep": "/riskfragor"
9 }
```

Response (400 Bad Request):

```

1 {
2   "success": false,
3   "error": "Minst_en_tjänst_måste_väljas",
4   "code": "NO_SERVICES_SELECTED"
5 }

```

Response (401 Unauthorized):

```

1 {
2   "success": false,
3   "error": "Ogiltig_eller_utgången_token",
4   "code": "INVALID_TOKEN"
5 }

```

Business Logic:

1. Hämta `user_id` från JWT token (Authorization header)
2. Validera att minst en tjänst är vald
3. Generera nytt UUID för onboarding-processen
4. Beräkna uppskattad kostnad baserat på prislista:
 - Löpande bokföring: 5000 kr/år
 - Årsbokslut: 8000 kr/år
 - Deklarationer: 3000 kr/år
 - Löneadministration: 4000 kr/år
 - Ekonomisk rådgivning: 10000 kr/år
 - Företagsregistrering: 15000 kr (engångsavgift)
 - Finansiell rapportering: 6000 kr/år
 - Företagsförsäljning/succession: Offert (kontakt)
5. Sätt riskindikator:
 - `foretagsregistrering = true` → `riskIndikator = "medium"` (nystartad = högre PTL-risk)
 - Annars → `riskIndikator = "low"`
6. Spara i databas (CSV under utveckling, PostgreSQL som slutoptimering)
7. Returnera `onboardingId` (UUID), uppskattad kostnad och nästa steg

Databas (SQL-syntax för framtida PostgreSQL, implementeras först som CSV):

```

1 -- Skapa ny onboarding-process
2 -- NUVARANDE IMPLEMENTATION: onboarding_processes.csv
3 -- FRAMTIDA OPTIMERING: PostgreSQL (efter att hela appen fungerar)
4 INSERT INTO onboarding_processes (
5   id,                -- UUID genererat av backend
6   user_id,           -- Från JWT token
7   status,            -- 'draft'
8   current_step,      -- 1
9   uppdrag_data,      -- JSONB med valda tjänster
10  uppskattad_kostnad, -- Beräknad kostnad
11  risk_indikator,    -- 'low' eller 'medium'
12  created_at,

```

```

13   updated_at
14 ) VALUES (
15   gen_random_uuid(),      -- PostgreSQL genererar UUID
16   $1,                     -- user_id
17   'draft',
18   1,
19   $2::jsonb,              -- uppdrag_data
20   $3,                     -- uppskattad_kostnad
21   $4,                     -- risk_indikator
22   NOW(),
23   NOW()
24 ) RETURNING id;          -- Returnera UUID till backend

```

Externa integrationer:

Inga (ren datalagring)

3 Sektion 2A: Riskfrågor – Steg 1

3.1 API-endpoints Sammanfattning (Våra endpoints)

- POST /api/onboarding/{onboardingId}/riskfragor/steg1 — Sparar grundfrågor, validerar mot externa API:er, beräknar triggers
- **Antal anrop vid sidladdning:** 0 (endpointen anropas när användaren klickar "Nästa")

3.2 Översikt - När anropas våra endpoints

Riskfrågor Steg 1 är första delen i en multi-stage wizard för riskbedömning enligt Penningtvättslagen (PTL). Användaren presenteras med 9 grundläggande frågor om företagets verksamhet, kunder och ägare.

React route: /riskfragor/steg1

React komponent: RiskFragorSteg1.jsx

Beamer slide: riskfragor-steg1

De 9 grundfrågorna:

1. Företagets huvudsakliga affärsidé (textarea)
2. Kundtyper (checkboxes: privatpersoner, företag, offentlig sektor)
3. Utländska affärspartners/kunder (textarea)
4. Största leverantörer (textarea)
5. Verksamhet ändrad senaste 12 månaderna (textarea)
6. Organisationsnummer (input)
7. Personnummer VD/Firmatecknare (input)
8. **Är det du som är verklig huvudman?** (radio: Ja >25%, Nej, Ej tillämpligt)
9. PEP-status (checkbox)

När användaren fyller i formuläret och klickar "Nästa" skickas ett POST-anrop till backend med alla svar. Backend validerar organisationsnummer och personnummer mot externa API:er (Bolagsverket, SPAR, Roaring), beräknar triggers för riskflaggor, och returnerar ALLTID:

- `nextStep` = "/riskfragor/steg2" (Steg 2-4 visas ALLTID, eller fler enligt `config.json`)
- `triggers` objekt används för risk-scoring och UI-betoning, INTE för att hoppa över steg
- Triggers kan påverka vilka frågor som betonas med varningar eller extra hjälptext

Vad används triggers till?

- Flagga risker i backend för compliance-team
- Betona specifika frågor i UI (t.ex. markera utländska transaktioner med varningsikon)
- Påverka slutlig risk-score (low/medium/high)
- Dokumentera varför Enhanced Due Diligence (EDD) kan krävas

3.3 Externa API-endpoints Sammanfattning

- POST /organisationer (Bolagsverket) — Validera org.nr, hämta VD/firmatecknare
- POST /navet/spar/personnummer (Skatteverket SPAR) — Validera personnummer, folkbokföring
- GET /se/company/beneficial-owners/2.1/{orgNr} (Roaring) — Hämta verkliga huvudmän >25%
- GET /se/company/alternative-beneficial-owner/1.0/{orgNr} (Roaring) — Hämta alternativ VH (VD) om ingen >25%
- GET /se/pep/1.0/{personnr} (Roaring) — PEP-kontroll per person
- GET /se/sanctions/1.0/{personnr} (Roaring) — Sanktionskontroll per person
- GET /se/businessprohibition/1.0/person/{personnr} (Roaring) — Näringsförbud per person

Totalt antal externa anrop: 3-9 beroende på antal verkliga huvudmän (se Implementation Notes)

3.4 Översikt - Varför behövs externa endpoints

PTL 3 kap 2 § kräver att vi identifierar och verifierar kunden (företaget) samt verkliga huvudmän. Detta innebär:

- **Bolagsverket:** Verifiera att organisationsnumret finns, hämta officiellt företagsnamn, SNI-kod, VD och firmatecknare. Endast personer registrerade som VD/firmatecknare får påbörja onboarding.
- **SPAR:** Verifiera att personnumret är korrekt och att personen är folkbokförd i Sverige. Hämta officiellt namn och adress för identitetskontroll.
- **Roaring Beneficial Owners:** PTL 3 kap 6 § kräver identifiering av verkliga huvudmän (fysiska personer som äger/kontrollerar >25%). Om ingen når tröskeln används PTL 3 kap 8 § (alternativ VH = högsta befattningshavare/VD).
- **Roaring PEP/Sanctions/Business Prohibition:** PTL 3 kap 10 § kräver screening mot PEP-listor och sanktionslistor. Näringsförbud är en extra kontroll enligt bokföringslagen.

Alla externa API-svar sparas i `external_api_responses` för audit trail och GDPR-compliance (rätt till tillgång).

3.5 Endpoint 1: POST /api/onboarding/{onboardingId}/riskfragor/steg1

3.5.1 Beskrivning

Sparar grundläggande riskfrågor (9 st.), validerar org.nr/personnr mot externa API:er (Bolagsverket, SPAR, Roaring), beräknar triggers för fördjupningsfrågor (Steg 2), och detekterar eventuell mismatch mellan användarens VH-påstående och Roaring.io:s register.

3.5.2 Request

Headers:

```

1 {
2   "Authorization": "Bearer_<access_token>",
3   "Content-Type": "application/json"
4 }

```

Body (pseudokod):

```

1 {
2   "affarsIde": "string (textarea)",
3   "kundTyper": {
4     "privatpersoner": boolean,
5     "foretag": boolean,
6     "offentligSektor": boolean
7   },
8   "utlandskaPartners": "string (textarea)",
9   "storaLeverantorer": "string (textarea)",
10  "verksamhetAndrad": "string (textarea)",
11  "organisationsnummer": "string (format: XXXXXX-XXXX)",
12  "personnummer": "string (format: YYYYMMDD-XXXX)",
13  "verkligHuvudman": "enum: ja_over_25 | nej | ej_tillampligt",
14  "isPEP": boolean
15 }

```

3.5.3 Response 200 OK - Inga riskflaggor

VIKTIGT: Denna response följer **Celestial Risk Engine v3.0** (se docs/Theory/metod_riskbedömni för fullständig metodbeskrivning).

```

1 {
2   "success": true,
3   "bolagsverketData": {
4     "foretagsnamn": "string",
5     "organisationsform": "string",
6     "sniKod": "string",
7     "sniBeskrivning": "string",
8     "registreringsdatum": "ISO-8601 date",
9     "status": "string"
10  },
11  "sparData": {
12    "namn": "string",
13    "personnummer": "string",
14    "folkbokforingsadress": "string",
15    "status": "string"
16  },
17  "riskAssessment": {
18    "staticKycScore": 12,
19    "adjustedScore": 32,
20    "hotBonus": 20,
21    "sniHotFactor": 3,
22    "riskLevel": "low",
23    "requiresEDD": false,

```

```

24     "components": {
25         "publicData": 4,
26         "crossValidation": 8,
27         "bookkeeping": 0
28     },
29     "triggers": {
30         "isPEP": false,
31         "hasSanctions": false,
32         "hasBusinessProhibition": false,
33         "vhMismatch": false,
34         "addressMismatch": true,
35         "missingFTax": false,
36         "missingVAT": false,
37         "newCompany": false,
38         "highRiskIndustry": true
39     }
40 },
41 "vhMismatch": {
42     "detected": false,
43     "reason": null,
44     "requiresManualReview": false
45 },
46 "wizardConfig": {
47     "totalSteps": 4,
48     "hasCustomConfig": false,
49     "steps": [
50         {
51             "id": 2,
52             "title": "Utländska transaktioner",
53             "isCustom": false
54         },
55         {
56             "id": 3,
57             "title": "Kunder & Affärspartners",
58             "isCustom": false
59         },
60         {
61             "id": 4,
62             "title": "Betalningar & Transaktioner",
63             "isCustom": false
64         }
65     ]
66 },
67 "message": "Grundläggande riskbedömning klar",
68 "nextStep": "/riskfragor/steg2"
69 }

```

OBS: nextStep är ALLTID `"/riskfragor/steg2"`. Backend läser användarens custom config.json (om uppladdad via Inställningar) och mergear med default Steg 2-4. Frontend renderar wizard-steg dynamiskt baserat på wizardConfig.steps.

Förklaring av riskAssessment:

- **staticKycScore**: Summan av publicData + crossValidation + bookkeeping (bookkeeping = 0 i Steg 1)
- **hotBonus**: $(\text{sniHotFactor} - 1) \times 10$ (Hot 1 = 0, Hot 2 = 10, Hot 3 = 20, Hot 4 = 30)
- **adjustedScore**: staticKycScore + hotBonus
- **sniHotFactor**: 1–4 från SNI-kod (se v3 metoddokument)
- **riskLevel**: low (0-40) / medium (41-70) / high (71-90) / critical (>90 eller hårda triggers)
- **requiresEDD**: true om Enhanced Due Diligence krävs (PTL 3 kap 10 §)
- **components**: Delpoäng per komponent (publicData max 30, crossValidation max 30, bookkeeping max 40)
- **triggers**: Boolean-flaggor för specifika riskfaktorer som påverkar score och åtgärder

3.5.4 Response 200 OK - Riskflaggor aktiva

```

1 {
2   "success": true,
3   "bolagsverketData": { ... },
4   "sparData": { ... },
5   "triggers": {
6     "showUtlandska": true,
7     "showKontanter": true,
8     "showVerksamhet": false,
9     "showPEP": false
10  },
11  "vhMismatch": {
12    "detected": false,
13    "reason": null,
14    "requiresManualReview": false
15  },
16  "wizardConfig": {
17    "totalSteps": 4,
18    "hasCustomConfig": false,
19    "steps": [ /* samma som ovan */ ]
20  },
21  "message": "Riskflaggor identifierade (se triggers för detaljer)",
22  "nextStep": "/riskfragor/steg2"
23 }
```

OBS: Samma nextStep och wizardConfig som vid inga triggers. Skillnaden är att triggers används för risk-scoring och kan påverka UI-presentation (betona frågor med varningsikoner).

3.5.5 Response 200 OK - VH Mismatch Detected (Warning)

```

1 {
2   "success": true,
3   "bolagsverketData": { ... },
4   "sparData": { ... },
```

```

5  "triggers": { ... },
6  "vhMismatch": {
7    "detected": true,
8    "reason": "User claims VH but not found in Roaring register",
9    "requiresManualReview": true,
10   "details": {
11     "userPersonnummer": "196505011234",
12     "roaringVH": [
13       {"personnummer": "198012251234", "shares": 45.5},
14       {"personnummer": "197503201234", "shares": 30.0}
15     ]
16   }
17 },
18 "wizardConfig": {
19   "totalSteps": 4,
20   "hasCustomConfig": false,
21   "steps": [ /* samma som ovan */ ]
22 },
23 "warning": "Din uppgift om verklig huvudman stämmer inte med
24   offentliga register. En redovisningskonsult kommer att
25   kontakta dig för klargörande.",
26 "message": "Riskbedömning klar (manuell granskning krävs)",
27 "nextStep": "/riskfragor/steg2"
28 }

```

OBS: VH-mismatch BLOCKERAR INTE processen. Användaren kan fortsätta, men ärendet flaggas för manuell granskning i Admin Dashboard.

3.5.6 Response 200 OK - Med Custom Config

```

1  {
2    "success": true,
3    "bolagsverketData": { ... },
4    "sparData": { ... },
5    "triggers": { ... },
6    "vhMismatch": { ... },
7    "wizardConfig": {
8      "totalSteps": 6,
9      "hasCustomConfig": true,
10     "customConfigVersion": "v2.1",
11     "steps": [
12       {
13         "id": 2,
14         "title": "Utländska transaktioner",
15         "isCustom": false,
16         "questionCount": 3
17       },
18       {
19         "id": 3,
20         "title": "Kunder & Affärspartners",
21         "isCustom": false,

```

```

22     "questionCount": 3
23 },
24 {
25     "id": 4,
26     "title": "Betalingar & Transaktioner",
27     "isCustom": false,
28     "questionCount": 5
29 },
30 {
31     "id": 5,
32     "title": "Miljöhänsyn & Hållbarhet",
33     "isCustom": true,
34     "questionCount": 4,
35     "questions": [
36         {
37             "id": "env_1",
38             "text": "Har företaget miljöcertifiering?",
39             "type": "radio",
40             "options": ["Ja", "Nej", "Under arbete"]
41         },
42         {
43             "id": "env_2",
44             "text": "Beskriv företags miljöpolicy",
45             "type": "textarea",
46             "maxLength": 500
47         }
48         /* ... fler frågor ... */
49     ]
50 },
51 {
52     "id": 6,
53     "title": "IT-säkerhet & GDPR",
54     "isCustom": true,
55     "questionCount": 6,
56     "questions": [ /* ... */ ]
57 }
58 ]
59 },
60 "message": "Grundläggande riskbedömning klar (+ 2 anpassade steg)",
61 "nextStep": "/riskfragor/steg2"
62 }

```

OBS: Backend läser användarens custom config.json (uppladdad via POST /api/user/settings/config) och mergear med default Steg 2-4. Custom steg kan INTE ersätta default steg 2-4, endast läggas till efter dem.

3.5.7 Response 400 Bad Request

```

1 {
2     "success": false,

```

```

3  "error": "validation_error",
4  "code": "INVALID_ORG_NUMBER",
5  "details": "Organisationsnummer måste vara 10 siffror (XXXXXX-XXXX)"
6  }

```

3.5.8 Response 403 Forbidden

```

1  {
2  "success": false,
3  "error": "not_authorized",
4  "code": "PERSON_NOT_AUTHORIZED",
5  "details": "Personnummer stämmer inte med VD/firmatecknare enligt Bolagsverket"
6  }

```

3.5.9 Response 404 Not Found

```

1  {
2  "success": false,
3  "error": "not_found",
4  "code": "COMPANY_NOT_FOUND",
5  "orgNr": "556789-1234"
6  }

```

3.5.10 Implementation Notes

Flöde (pseudokod):

```

1  1. Extrahera user_id från JWT token
2  2. SELECT onboarding_process WHERE id = onboardingId AND user_id = user_id
3     OM INTE HITTAT → 403 Forbidden
4  3. Validera request body format:
5     - org.nr: Regex XXXXXX-XXXX
6     - personnr: Regex YYYYMMDD-XXXX
7     - verkligHuvudman: Enum ["ja_over_25", "nej", "ej_tillampligt"]
8  4. Anropa Bolagsverket API (POST /organisationer)
9     SPARA response i external_api_responses
10 5. Anropa SPAR API (POST /navet/spar/personnummer)
11    SPARA response i external_api_responses
12 6. Verifiera personnummer mot VD/firmatecknare från Bolagsverket
13    OM INGEN MATCH → 403 Forbidden
14 7. Anropa Roaring Beneficial Owners (två-steps algoritm):
15    a. GET /beneficial-owners/2.1/{orgNr}
16    b. OM tom array → GET /alternative-beneficial-owner/1.0/{orgNr}
17    SPARA båda responses i external_api_responses
18 8. Kontrollera VH-mismatch (verklig huvudman-validering):
19    OM verkligHuvudman === "ja_over_25":

```

```

20     personnr_from_form = request.personnummer
21     vh_from_roaring = external_api_responses.beneficial_owners
22     OM personnr_from_form INTE finns i vh_from_roaring:
23         FLAGGA mismatch_detected = true
24         SPARA mismatch_reason = "User claims VH but not in Roaring
           register"
25         LOG event: "VH_MISMATCH_DETECTED" med detaljer
26         SET requires_manual_review = true
27     ANNARS:
28         mismatch_detected = false
29 9. FÖR varje VH (verklig huvudman från Roaring):
30     a. GET /pep/1.0/{personnr}
31     b. GET /sanctions/1.0/{personnr}
32     c. GET /businessprohibition/1.0/person/{personnr}
33     SPARA alla responses i external_api_responses
34 10. Beräkna triggers baserat på API-svar och avvikelser:
35
36     A. BASERAD PÅ ANVÄNDARENS INPUT (sparas för riskbedömning):
37     userFlags.hasInternationalPartners = (utlandskaPartners ≠ "Nej
           ")
38     userFlags.servesCash = (kundTyper.privatpersoner === true)
39     userFlags.recentChanges = (verksamhetAndrad ≠ "Nej")
40     userFlags.selfReportedPEP = (isPEP === true)
41
42     B. TRIGGERS FRÅN API-AVVIKELSER (triggar extra åtgärder):
43     triggers.pepDetected = (någon VH.isPEP === true FROM Roaring)
44     triggers.newCompany = (registrationDate < 6 månader FROM
           Bolagsverket)
45     triggers.addressMismatch = (SPAR adress ≠ Bolagsverket adress)
46     triggers.missingFTax = (fTaxReg === false FROM Roaring)
47     triggers.missingVAT = (vatReg === false FROM Roaring AND omsä
           ttning >80k)
48     triggers.vhMismatch = (mismatch_detected === true FROM steg 8)
49     triggers.sanctioned = (någon VH.isSanctioned === true FROM
           Roaring)
50     triggers.businessProhibition = (någon VH.hasProhibition === true
           )
51     triggers.highRiskIndustry = (SNI-kod i högrisklista FROM
           metoddokument)
52
53     C. KOMBINATION (behövs för Celestial Engine):
54     riskProfile = {
55         userFlags: userFlags,
56         apiTriggers: triggers,
57         combinedRiskScore: calculate_celestial_score(userFlags,
           triggers)
58     }
59
60 11. UPDATE onboarding_processes SET
61     riskfragor_steg1 = request_body,
62     bolagsverket_data = bolagsverket_response,

```

```

63     spar_data = spar_response,
64     beneficial_owners_data = roaring_response,
65     vh_mismatch_detected = mismatch_detected,
66     vh_mismatch_reason = mismatch_reason,
67     requires_manual_review = requires_manual_review,
68     user_flags = userFlags,
69     api_triggers = triggers,
70     risk_profile = riskProfile,
71     current_step = 2,
72     updated_at = NOW()
73 WHERE id = onboardingId
74 12. Läs användarens custom config (om uppladdad):
75     custom_config = SELECT custom_wizard_config FROM user_settings
76                       WHERE user_id = user_id
77 OM custom_config finns:
78     wizard_config = merge_wizard_steps(DEFAULT_STEPS_2_4,
79                                       custom_config.additionalSteps)
80     wizard_config.hasCustomConfig = true
81     wizard_config.totalSteps = len(wizard_config.steps)
82 ANNARS:
83     wizard_config = DEFAULT_STEPS_2_4
84     wizard_config.hasCustomConfig = false
85     wizard_config.totalSteps = 4
86 OBS: Custom steg kan INTE ersätta Steg 2-4, endast läggas till
87     som Steg 5, 6, 7...
88 13. Beräkna nextStep:
89     nextStep = "/riskfragor/steg2" (ALLTID - Steg 2-N körs alltid)
90 OBS: Triggers används för risk-scoring och UI-betoning, INTE fö
91     r att hoppa över steg
92 14. Returnera response med nextStep="/riskfragor/steg2",
93     wizardConfig, triggers (och mismatch_warning om flaggad)

```

Valideringsregler:

- org_nr: Format XXXXXX-XXXX, måste finnas i Bolagsverket
- personnr: Format YYYYMMDD-XXXX, måste vara VD/firmatecknare enligt Bolagsverket
- personnr: Måste vara folkbokförd enligt SPAR
- verkligHuvudman: Enum ["ja_over_25", "nej", "ej_tillampligt"]
- affarsIde: Max 1000 tecken
- utlandskaPartners: Max 1000 tecken
- storaLeverantorer: Max 1000 tecken
- verksamhetAndrad: Max 1000 tecken

VH-Mismatch Hantering:

- **Vad är en mismatch?** Användaren svarar "Ja, jag är VH >25%" men deras personnummer finns INTE i Roaring.io:s VH-register
- **Varför kan detta hända?**
 - Roaring.io:s data är utdaterad (uppdateras kvartalsvis från Bolagsverket)
 - Nyligen gjord ägarförändring (ännu ej registrerad)

- Indirekta ägare via holdingbolag (Roaring visar bara direktägande)
- Användaren har missförstått definitionen av "verklig huvudman" (PTL 1 kap 3-6 §§)

- **Hur hanterar vi det?**

- Flagga onboarding för manuell granskning (`requires_manual_review = true`)
- Logga händelse med detaljer (personnr från form, VH från Roaring)
- Backend returnerar varning i response (men BLOCKERAR INTE processen)
- Admin Dashboard visar flaggade fall för manuell kontroll
- Redovisningskonsult kontaktar kunden för klargörande

- **Omvänd situation:** Användaren svarar "Nej" men Roaring visar dem som VH >25%

- Kan vara legitimt (ägarandelen precis under 25%, eller indirekt ägande)
- Flagga OCKSÅ för manuell granskning
- LOG event: "VH_REVERSE_MISMATCH_DETECTED"

Trigger-definition och koppling till Celestial Risk Engine v3.0:

VIKTIGT: Fullständig metodbeskrivning finns i docs/Theory/metod_riskbedömning_kund_

Tidigare version (Hot×Sårbarhet-modell) har ersatts med **Celestial Risk Engine**

0–100 poäng-modell:

1. **staticKycScore** (0–100): Beräknas från tre komponenter
 - Offentliga register (max 30 poäng): Bolagsålder, PEP, sanktioner, näringsförbud
 - Korsvalidering (max 30 poäng): VH-mismatch, adressmismatch, F-skatt/moms-avvikelser
 - Bokföringsdata (max 40 poäng): Sätts till 0 i Steg 1, fylls i vid SIE-analys
2. **sniHotFactor** (1–4): Hämtas från SNI-kod via Bolagsverket
 - 1 = Lågrisk (IT, konsult, design)
 - 2 = Normal risk (handel, tillverkning)
 - 3 = Förhöjd risk (restaurang, taxi, kontantintensiv)
 - 4 = Hög risk (spelverksamhet, valutaväxling, ädelmetaller)
3. **adjustedScore**: `staticKycScore + hotBonus
 - Hot 1: score + 0 poäng
 - Hot 2: score + 10 poäng
 - Hot 3: score + 20 poäng
 - Hot 4: score + 30 poäng`
4. **riskLevel** (fyrgradig skala enligt FFFS 2009:1):
 - low: `adjustedScore` 0–40
 - medium: `adjustedScore` 41–70
 - high: `adjustedScore` 71–90
 - critical: `adjustedScore` > 90 ELLER hårda triggers
5. **Hårda triggers (automatisk critical-klassning):**
 - `hasSanctions = true` → STOPP, avslag av uppdrag
 - `hasBusinessProhibition = true` → STOPP, avslag av uppdrag
 - Kombination: VH-mismatch + saknad F-skatt + PEP → kritisk granskning

6. Eskaleringstriggrar (höjer riskklass ett steg om på gräns):

- `isPEP = true + score > 35` → Low blir Medium
- `vhMismatch = true + score > 60` → Medium blir High
- `addressMismatch = true + highRiskIndustry = true` → Betoning

Kostnad externa API-anrop:

- **Best Case (2 VH direktgående):** Bolagsverket (1) + SPAR (1) + Roaring BO (1) + (2 VH × 3 checks) = 9 anrop
- **Worst Case (alternativ VH):** Bolagsverket (1) + SPAR (1) + Roaring BO (2) + (1 VH × 3 checks) = 7 anrop

3.6 Extern Endpoint 1: POST /organisationer (Bolagsverket)

3.6.1 Beskrivning

Validerar organisationsnummer och hämtar grundläggande företagsinformation inklusive VD och firmatecknare från Bolagsverkets officiella register.

Fullständig URL: <https://portal.api.bolagsverket.se/open/v1/companies>

3.6.2 Request

Headers:

```
1 {
2   "Content-Type": "application/json"
3 }
```

Body (pseudokod):

```
1 {
2   "organisationsnummer": ["556903-8671"]
3 }
```

3.6.3 Response 200 OK

```
1 {
2   "organisationer": [
3     {
4       "organisationsnummer": "string",
5       "namn": "string",
6       "organisationsform": "string (AB, HB, etc.)",
7       "sniKod": "string",
8       "sniBeskrivning": "string",
9       "registreringsdatum": "ISO-8601 date",
10      "status": "string (Aktiv, Avregistrerad)",
11      "vd": {
12        "namn": "string",
13        "personnummer": "string"
14      },
15      "firmatecknare": [
```

```

16     {
17         "namn": "string",
18         "personnummer": "string",
19         "firmateckningsregel": "string"
20     }
21 ]
22 }
23 ]
24 }

```

3.6.4 Implementation Notes för Response

Validering (pseudokod):

```

1 1. Extrahera organisationer array från response
2 2. OM tom array → REJECT med 404 Not Found
3 3. Extrahera första org från array (endast en förväntad)
4 4. OM org.status ≠ "Aktiv" → REJECT med 400 Bad Request
5 5. Extrahera VD personnummer: vd_personnr = org.vd.personnummer
6 6. Extrahera firmatecknare personnummer: firmatecknare_list = org.
   firmatecknare.map(ft => ft.personnummer)
7 7. Jämför användaren angett personnummer mot VD och firmatecknare:
8   OM (user_personnr === vd_personnr OR user_personnr IN
   firmatecknare_list)
9   → GODKÄND
10 ANNARS
11   → REJECT med 403 Forbidden ("Du är inte VD eller
   firmatecknare")
12 8. Spara hela org-objektet i onboarding_processes.bolagsverket_data
13 9. Spara hela response i external_api_responses tabell för audit
   trail

```

3.7 Extern Endpoint 2: POST /navet/spar/personnummer (Skatteverket SPAR)

3.7.1 Beskrivning

Validerar personnummer och hämtar folkbokföringsuppgifter från Skatteverkets SPAR-register (Svenska PersonAdressRegistret).

Fullständig URL: <https://navet.skatteverket.se/spar/personnummer>

OBS: Kräver X.509-certifikat för autentisering (test-certifikat för utveckling, prod-certifikat för produktion).

3.7.2 Request

Headers:

```

1 {
2   "Content-Type": "application/json"
3 }

```

Body (pseudokod):

```
1 {
2   "personnummer": "195001011234",
3   "syfte": "Kundkännedom enligt PTL"
4 }
```

3.7.3 Response 200 OK

```
1 {
2   "personnummer": "string",
3   "namn": {
4     "fornamn": "string",
5     "efternamn": "string"
6   },
7   "folkbokforingsadress": {
8     "adress": "string",
9     "postnummer": "string",
10    "postort": "string"
11  },
12  "status": "string (Folkbokförd, Avregistrerad, Emigrerad)",
13  "fodelsedatum": "ISO-8601 date"
14 }
```

3.7.4 Implementation Notes för Response

Validering (pseudokod):

```
1 1. OM response.status != "Folkbokförd" → VARNING (inte
   blockerande, men flagga för manuell granskning)
2 2. Extrahera fullständigt namn: fullName = fornamn + " " +
   efternamn
3 3. Jämför namn mot Bolagsverket VD-namn (fuzzy match för att
   hantera skiljetecken):
4   OM (fuzzyMatch(sparNamn, bolagsverketVdNamn) < 80% match)
5   → VARNING (namndiskrepans - flagga för manuell granskning)
6 4. Spara hela SPAR-objektet i onboarding_processes.spar_data
7 5. Spara hela response i external_api_responses tabell för audit
   trail
```

3.8 Extern Endpoint 3: GET /se/company/beneficial-owners/2.1/{orgNr} (Roaring)

3.8.1 Beskrivning

Hämtar registrerade verkliga huvudmän från Bolagsverkets register över verkliga huvudmän. Returnerar endast personer som äger/kontrollerar >25% enligt PTL 3 kap 6 §.

Fullständig URL: <https://api.roaring.io/se/company/beneficial-owners/2.1/{orgNr}>

PTL-grund: PTL 3 kap 6 § - Identifiering av verklig huvudman

3.8.2 Request

Headers:

```
1 {
2   "Authorization": "Bearer <roaring_access_token>"
3 }
```

3.8.3 Response 200 OK - Med VH >25%

```
1 {
2   "organizationNumber": "string",
3   "companyName": "string",
4   "beneficialOwners": [
5     {
6       "personalNumber": "string",
7       "firstName": "string",
8       "lastName": "string",
9       "ownershipPercentage": float,
10      "votingRightsPercentage": float,
11      "ownershipType": "string (DIRECT, INDIRECT)",
12      "source": "string",
13      "verified": boolean
14    }
15  ],
16  "totalCoverage": float
17 }
```

3.8.4 Response 200 OK - Tom array (ingen >25%)

```
1 {
2   "organizationNumber": "string",
3   "companyName": "string",
4   "beneficialOwners": [],
5   "totalCoverage": 0.0
6 }
```

3.8.5 Implementation Notes för Response

Två-steps algoritm (pseudokod):

```
1 1. Anropa Primary Endpoint: GET /beneficial-owners/2.1/{orgNr}
2 2. OM beneficialOwners.length > 0:
3   → Använd dessa VH (registrerade ägare >25%)
4   → Gå till steg 8
5 3. OM beneficialOwners.length == 0:
6   → Ingen ägare >25%, använd fallback (PTL 3 kap 8 paragraf)
7   → Anropa Alternative Endpoint: GET /alternative-beneficial-
8     owner/1.0/{orgNr}
9 4. OM alternative response innehåller VD:
```

```

9      → Använd VD som alternativ VH
10     → Gå till steg 8
11 5. OM både primary OCH alternative ger tomt resultat:
12     → KRITISK ERROR (ingen VH identifierbar)
13     → REJECT onboarding
14 6. FÖR varje VH (från primary ELLER alternative):
15     a. GET /pep/1.0/{personnr}
16     b. GET /sanctions/1.0/{personnr}
17     c. GET /businessprohibition/1.0/person/{personnr}
18 7. Analysera PEP/Sanctions/BusinessProhibition:
19     OM isSanctioned = true → REJECT omedelbart
20     OM hasBusinessProhibition = true → REJECT omedelbart
21     OM isPEP = true → Sätt trigger showPEP = true
22 8. Spara alla VH i onboarding_processes.beneficial_owners_data
23 9. Spara alla responses i external_api_responses för audit trail

```

3.9 Extern Endpoint 4: GET /se/company/alternative-beneficial-owner/1.0/{orgNr} (Roaring)

3.9.1 Beskrivning

Hämtar alternativ verklig huvudman (VD/högsta befattningshavare) när ingen ägare når 25%-tröskeln enligt PTL 3 kap 8 §.

Fullständig URL: <https://api.roaring.io/se/company/alternative-beneficial-owner/1.0/{orgNr}>

PTL-grund: PTL 3 kap 8 § - Alternativ verklig huvudman (högsta befattningshavare)

3.9.2 Request

Headers:

```

1 {
2   "Authorization": "Bearer <roaring_access_token>"
3 }

```

3.9.3 Response 200 OK

```

1 {
2   "organizationNumber": "string",
3   "companyName": "string",
4   "alternativeBeneficialOwner": {
5     "personalNumber": "string",
6     "firstName": "string",
7     "lastName": "string",
8     "position": "string (VD, Styrelseordförande, etc.)",
9     "source": "string",
10    "verified": boolean
11  }
12 }

```

3.9.4 Implementation Notes för Response

Användning (pseudokod):

```
1 1. Anropas endast OM primary endpoint returnerar tom array
2 2. Extrahera alternativeBeneficialOwner från response
3 3. Verifiera att personnummer finns
4 4. Kör SAMMA PEP/Sanctions/BusinessProhibition checks som för
   vanlig VH
5 5. Markera i databasen att denna VH är "alternativ" (för
   rapportering)
```

3.10 Extern Endpoint 5: GET /se/pep/1.0/{personnr} (Roaring)

3.10.1 Beskrivning

Kontrollerar om person är Politically Exposed Person (PEP) enligt PTL 3 kap 10 §. Inkluderar nationella och internationella PEP-listor samt familjemedlemmar/nära medarbetare.

Fullständig URL: <https://api.roaring.io/se/pep/1.0/{personnr}>

3.10.2 Request

Headers:

```
1 {
2   "Authorization": "Bearer <roaring_access_token>"
3 }
```

3.10.3 Response 200 OK - Är PEP

```
1 {
2   "personalNumber": "string",
3   "isPEP": true,
4   "pepType": "string (DOMESTIC, FOREIGN, RCA)",
5   "position": "string",
6   "organization": "string",
7   "activeSince": "ISO-8601 date",
8   "activeUntil": "ISO-8601 date (nullable)"
9 }
```

3.10.4 Response 200 OK - Inte PEP

```
1 {
2   "personalNumber": "string",
3   "isPEP": false
4 }
```

3.10.5 Implementation Notes för Response

Hantering (pseudokod):

```
1 1. OM isPEP = true:  
2   → Sätt trigger showPEP = true  
3   → Spara PEP-detalljer för fördjupade frågor i Steg 2  
4   → Fortsätt onboarding (PEP är INTE blockerande, kräver bara  
   EDD)  
5 2. OM isPEP = false:  
6   → Ingen ytterligare åtgärd
```

3.11 Extern Endpoint 6: GET /se/sanctions/1.0/{personnr} (Roaring)

3.11.1 Beskrivning

Kontrollerar om person finns på sanktionslistor (EU, UN, OFAC, etc.). Detta är BLOCKERANDE - om personen är sanktionerad MÅSTE onboarding avbrytas omedelbart.

Fullständig URL: <https://api.roaring.io/se/sanctions/1.0/{personnr}>

3.11.2 Request

Headers:

```
1 {  
2   "Authorization": "Bearer <roaring_access_token>"  
3 }
```

3.11.3 Response 200 OK - Är sanktionerad

```
1 {  
2   "personalNumber": "string",  
3   "isSanctioned": true,  
4   "sanctionLists": [  
5     {  
6       "listName": "string (EU Sanctions, UN Sanctions, etc.)",  
7       "addedDate": "ISO-8601 date",  
8       "reason": "string"  
9     }  
10  ]  
11 }
```

3.11.4 Response 200 OK - Inte sanktionerad

```
1 {  
2   "personalNumber": "string",  
3   "isSanctioned": false  
4 }
```

3.11.5 Implementation Notes för Response

Hantering (pseudokod):

```
1 1. OM isSanctioned = true:
2   → REJECT onboarding OMEDELBART
3   → Returnera 403 Forbidden med message: "Sanktionerad person -
4     onboarding ej möjlig"
5   → Logga incident för compliance-team
6   → AVSLUTA
7 2. OM isSanctioned = false:
   → Fortsätt onboarding
```

3.12 Extern Endpoint 7: GET /se/businessprohibition/1.0/person/{personnr} (Roaring)

3.12.1 Beskrivning

Kontrollerar om person har näringsförbud enligt bokföringslagen. Näringsförbud innebär att personen inte får driva företag och är BLOCKERANDE för onboarding.

Fullständig URL: <https://api.roaring.io/se/businessprohibition/1.0/person/{personnr}>

3.12.2 Request

Headers:

```
1 {
2   "Authorization": "Bearer <roaring_access_token>"
3 }
```

3.12.3 Response 200 OK - Har näringsförbud

```
1 {
2   "personalNumber": "string",
3   "hasBusinessProhibition": true,
4   "prohibitionStart": "ISO-8601 date",
5   "prohibitionEnd": "ISO-8601 date",
6   "reason": "string"
7 }
```

3.12.4 Response 200 OK - Inget näringsförbud

```
1 {
2   "personalNumber": "string",
3   "hasBusinessProhibition": false
4 }
```

3.12.5 Implementation Notes för Response

Hantering (pseudokod):

```
1 1. OM hasBusinessProhibition = true:
2   → REJECT onboarding OMEDELBART
3   → Returnera 403 Forbidden med message: "Näringsförbud -
4     onboarding ej möjlig"
5   → Logga incident för compliance-team
6   → AVSLUTA
7 2. OM hasBusinessProhibition = false:
   → Fortsätt onboarding
```

3.13 Backend Persistent Lagring

Tabell: onboarding_processes

```
1 -- Utöka befintlig tabell med kolumner för Steg 1
2 ALTER TABLE onboarding_processes
3 ADD COLUMN IF NOT EXISTS riskfragor_steg1 JSONB,
4 ADD COLUMN IF NOT EXISTS bolagsverket_data JSONB,
5 ADD COLUMN IF NOT EXISTS spar_data JSONB,
6 ADD COLUMN IF NOT EXISTS beneficial_owners_data JSONB,
7 ADD COLUMN IF NOT EXISTS triggers JSONB DEFAULT '{} '::jsonb,
8 ADD COLUMN IF NOT EXISTS red_flags JSONB DEFAULT '[] '::jsonb,
9 ADD COLUMN IF NOT EXISTS vh_mismatch_detected BOOLEAN DEFAULT false
10 ,
11 ADD COLUMN IF NOT EXISTS vh_mismatch_reason TEXT,
12 ADD COLUMN IF NOT EXISTS requires_manual_review BOOLEAN DEFAULT
13   false;
14
15 -- Index för snabba sökningar
16 CREATE INDEX IF NOT EXISTS idx_onboarding_triggers
17   ON onboarding_processes USING GIN (triggers);
18 CREATE INDEX IF NOT EXISTS idx_onboarding_red_flags
19   ON onboarding_processes USING GIN (red_flags);
20 CREATE INDEX IF NOT EXISTS idx_manual_review
21   ON onboarding_processes (requires_manual_review)
22   WHERE requires_manual_review = true;
```

Tabell: external_api_responses

```
1 -- Logga alla externa API-anrop för audit trail och GDPR
2 CREATE TABLE IF NOT EXISTS external_api_responses (
3   id UUID PRIMARY KEY DEFAULT gen_random_uuid(),
4   onboarding_id UUID NOT NULL REFERENCES onboarding_processes(id),
5   api_name VARCHAR(100) NOT NULL, -- "bolagsverket", "spar", "
6     roaring-pep", etc.
7   endpoint VARCHAR(255) NOT NULL, -- "/organisationer", "/pep
8     /1.0/{personnr}", etc.
9   request_data JSONB, -- Request body (om relevant)
10  response_data JSONB, -- Fullständig response
11  response_code INTEGER, -- HTTP status code
```

```

10     created_at TIMESTAMP DEFAULT NOW()
11 );
12
13 -- Index för snabba sökningar
14 CREATE INDEX IF NOT EXISTS idx_api_responses_onboarding
15     ON external_api_responses(onboarding_id);
16 CREATE INDEX IF NOT EXISTS idx_api_responses_api_name
17     ON external_api_responses(api_name);
18 CREATE INDEX IF NOT EXISTS idx_api_responses_created
19     ON external_api_responses(created_at);

```

Update-query (pseudokod):

```

1 UPDATE onboarding_processes
2 SET
3     riskfragor_steg1 = $request_body,
4     bolagsverket_data = $bolagsverket_response,
5     spar_data = $spar_response,
6     beneficial_owners_data = $roaring_beneficial_owners,
7     triggers = $calculated_triggers,
8     red_flags = $detected_red_flags,
9     current_step = 2,
10    status = 'in_progress',
11    updated_at = NOW()
12 WHERE id = $onboardingId
13    AND user_id = $user_id_from_jwt;

```

3.14 Frontend Datalagring i Browser

3.14.1 localStorage

- onboardingId (UUID) — Identifierar processen, sätts av POST /uppdrag
- currentStep (Integer) — Vilket steg användaren är på (0-7)
- riskfragorSteg1Draft (JSON) — Autosave medan användaren fyller i formulär
- triggers (JSON) — Vilka riskflaggor som är aktiva (används för UI-betoning)
- wizardConfig (JSON) — Wizard-steg från backend (default + custom från config.json)
- bolagsverketData (JSON) — Cached företagsinformation för visning
- sparData (JSON) — Cached personuppgifter för visning

Exempel localStorage efter Steg 1 (utan custom config):

```

1 {
2   "onboardingId": "550e8400-e29b-41d4-a716-446655440000",
3   "currentStep": 2,
4   "triggers": {
5     "showUtlandska": true,
6     "showKontanter": false,
7     "showVerksamhet": false,
8     "showPEP": false
9   },
10  "wizardConfig": {

```

```

11     "totalSteps": 4,
12     "hasCustomConfig": false,
13     "steps": [
14       {"id": 2, "title": "Utländska_transaktioner", "isCustom":
15         false},
16       {"id": 3, "title": "Kunder_&_Affärspartners", "isCustom":
17         false},
18       {"id": 4, "title": "Betalningar_&_Transaktioner", "isCustom":
19         false}
20     ]
21   },
22   "bolagsverketData": {
23     "foretagsnamn": "Exempel_AB",
24     "sniKod": "47111",
25     "sniBeskrivning": "Livsmedelsbutiker"
26   }
27 }

```

Exempel localStorage efter Steg 1 (med custom config från Inställningar):

```

1 {
2   "onboardingId": "550e8400-...",
3   "currentStep": 2,
4   "wizardConfig": {
5     "totalSteps": 6,
6     "hasCustomConfig": true,
7     "customConfigVersion": "v2.1",
8     "steps": [
9       {"id": 2, "title": "Utländska_transaktioner", "isCustom":
10        false},
11       {"id": 3, "title": "Kunder_&_Affärspartners", "isCustom":
12        false},
13       {"id": 4, "title": "Betalningar_&_Transaktioner", "isCustom":
14        false},
15       {"id": 5, "title": "Miljöhänsyn_&_Hållbarhet", "isCustom":
16        true, "questionCount": 4},
17       {"id": 6, "title": "IT-säkerhet_&_GDPR", "isCustom": true, "
18        questionCount": 6}
19     ]
20   }
21 }

```

3.14.2 Cookies

- **access_token** (HttpOnly, Secure, SameSite=Strict) — JWT access token för API-autentisering
- **refresh_token** (HttpOnly, Secure, SameSite=Strict) — JWT refresh token för token renewal

Inga cookies specifika för Riskfrågor Steg 1.

3.15 Backend - Behandlingshistorik och GDPR

3.15.1 Loggade händelser

Alla API-anrop och viktiga händelser loggas för GDPR-compliance (rätt till tillgång) och audit trail.

- `riskfragor_steg1_started` — När användaren besöker sliden
- `riskfragor_steg1_autosave` — När formulär auto-sparas (localStorage)
- `riskfragor_steg1_submitted` — När användaren klickar "Nästa"
- `bolagsverket_api_called` — Organisationsnummer validering
- `spar_api_called` — Personnummer validering
- `roaring_beneficial_owner_primary_called` — VH >25% check
- `roaring_beneficial_owner_alternative_called` — Alternativ VH check (om behövs)
- `vh_mismatch_detected` — (NYT) Användaren hävdar VH men finns ej i Roaring
- `vh_reverse_mismatch_detected` — (NYT) Roaring visar VH men användaren nekar
- `manual_review_flagged` — (NYT) Ärendet flaggat för manuell granskning
- `roaring_pep_called` — PEP-kontroll per VH
- `roaring_sanctions_called` — Sanktionskontroll per VH
- `roaring_businessprohibition_called` — Näringsförbud per VH
- `triggers_calculated` — Vilka fördjupningsfrågor triggades
- `red_flags_detected` — Om PEP/Sanctions/BusinessProhibition hittades
- `onboarding_rejected` — Om sanktionerad eller näringsförbud

3.15.2 CSV-filer (Primär databasimplementation)

UTVECKLINGSSTRATEGI: Hela applikationen byggs FÖRST med CSV-filer för ALL databashantering. PostgreSQL införs som slutoptimering ENDAST efter att hela applikationen fungerar felfritt. Detta undviker race conditions och concurrent write-problem under utveckling.

Varför CSV först?

- Enklare debugging (kan öppna CSV i editor och se exakt vad som sparats)
- Inga databaskonfigurationsproblem under utveckling
- Snabbare iterationer (ingen migration/schema-hantering)
- Fungerar perfekt för single-user development environment
- PostgreSQL blir "drop-in replacement" när applikationen är stabil

onboarding_processes.csv:

```
1 id,user_id,riskfragor_steg1,triggers,vh_mismatch_detected,
  requires_manual_review,current_step,created_at,updated_at
2 550e8400-...,123e4567-...,"{\"affarsIde\":\"...\"}","{\"showUtlandska\":true}",false,false,2,2025-10-24T10:00:00Z
  ,2025-10-24T10:05:00Z
```

external_api_responses.csv:

```
1 id,onboarding_id,api_name,endpoint,response_code,response_body,
  created_at
```

```

2  uuid1,550e8400-...,bolagsverket,/organisationer,200,"{"\"
   foretagsnamn\":\"...\"}",2025-10-24T10:01:00Z
3  uuid2,550e8400-...,spar,/navet/spar/personnummer,200,"{"\"namn
   \":\"...\"}",2025-10-24T10:02:00Z
4  uuid3,550e8400-...,roaring_pep,/pep/1.0/195001011234,200,\"{"\"isPEP
   \":false}",2025-10-24T10:03:00Z

```

event_log.csv:

```

1  id,onboarding_id,event_type,user_id,details,created_at
2  uuid1,550e8400-...,riskfragor_steg1_submitted,123e4567-...,{"\"step
   \":1}",2025-10-24T10:05:00Z
3  uuid2,550e8400-...,vh_mismatch_detected,123e4567-...,{"\"reason
   \":\"...\"}",2025-10-24T10:05:30Z

```

3.16 Databastabeller (Framtida PostgreSQL-optimering)

OBS: SQL-scheman nedan dokumenterar framtida PostgreSQL-implementation. NUVA-RANDE implementation använder CSV-filer med samma struktur. PostgreSQL införs som slutoptimering för multi-user concurrent access. Se sektion "Backend Persistent Lagring" ovan för fullständigt SQL-schema.

Sammanfattning:

- **onboarding_processes** — Huvudtabell, innehåller riskfragor_steg1, triggers, bolagsverket_data, spar_data, beneficial_owners_data, red_flags
- **external_api_responses** — Audit trail för alla externa API-anrop, sparar request + response för GDPR-compliance
- **user_settings** — Innehåller custom_wizard_config (JSON) per användare
- Index på triggers (GIN för JSONB) och red_flags (GIN för JSONB) för snabba sökningar

3.17 Custom Wizard Config (Valfri anpassning via Inställningar)

3.17.1 Översikt

Användare kan ladda upp en custom config.json via Inställningar-sidan för att lägga till EGNA wizard-steg (Steg 5, 6, 7...) med anpassade frågor. De obligatoriska Steg 2-4 kan INTE ersättas eller tas bort, endast kompletteras.

När läses config.json? Backend läser användarens custom config vid POST /riskfragor/steg1 (precis innan Steg 2 ska visas). Detta är den ENKLASTE approachen — ingen extra API-anrop, ingen cache-invalidation, alltid uppdaterad config.

3.17.2 Upload Endpoint

Endpoint: POST /api/user/settings/config

Request:

```

1  {
2    "configFile": "base64-encoded JSON eller multipart/form-data",
3    "version": "v2.1" // valfri versionstagg
4  }

```

Response 200 OK:

```
1 {
2   "success": true,
3   "message": "Custom wizard config sparad",
4   "totalStepsAdded": 2,
5   "configVersion": "v2.1"
6 }
```

Backend sparar:

```
1 -- CSV: user_settings.csv
2 -- SQL (framtida):
3 UPDATE user_settings
4 SET custom_wizard_config = $1::jsonb,
5     config_version = $2,
6     updated_at = NOW()
7 WHERE user_id = $3;
```

3.17.3 Config.json Structure

```
1 {
2   "version": "v2.1",
3   "additionalSteps": [
4     {
5       "id": 5,
6       "title": "Miljöhänsyn & Hållbarhet",
7       "description": "Frågor om företags miljöarbete",
8       "conditional": false,
9       "questions": [
10        {
11          "id": "env_1",
12          "text": "Har företaget miljöcertifiering (t.ex. ISO 14001)?",
13          "type": "radio",
14          "required": true,
15          "options": ["Ja", "Nej", "Under arbete"]
16        },
17        {
18          "id": "env_2",
19          "text": "Beskriv företags miljöpolicy (om tillämpligt)",
20          "type": "textarea",
21          "required": false,
22          "maxLength": 500,
23          "placeholder": "T.ex. återvinning, koldioxidkompensation ..."
24        },
25        {
26          "id": "env_3",
27          "text": "Hållbarhetsrapportering enligt GRI/CSRD?",
28          "type": "checkbox",
```

```

29         "required": false,
30         "label": "Ja, vi rapporterar enligt standarder"
31     }
32 ]
33 },
34 {
35     "id": 6,
36     "title": "IT-säkerhet & GDPR",
37     "description": "Frågor om informationssäkerhet",
38     "conditional": false,
39     "questions": [
40         {
41             "id": "it_1",
42             "text": "Har företaget utsett ett dataskyddsombud (DPO)?"
43             ,
44             "type": "radio",
45             "required": true,
46             "options": ["Ja", "Nej", "Ej tillämpligt (< 250 anställda)"]
47         },
48         {
49             "id": "it_2",
50             "text": "Genomförs regelbundna säkerhetsrevisioner?",
51             "type": "radio",
52             "required": true,
53             "options": ["Ja, årligen", "Ja, vartannat år", "Nej", "Planerat"]
54         }
55     ]
56 }
57 ]

```

3.17.4 Regler för Custom Config

- **Steg 2-4 är obligatoriska** — Custom steg får ENDAST id 5 och uppåt
- **Max 10 additional steps** — För att undvika orimligt långa wizards
- **Max 20 questions per step** — För att hålla steg hanterliga
- **Conditional steg** — Kan använda triggers från Steg 1 (men rekommenderas ej för enkelhet)
- **Question types** — Stödda typer: radio, checkbox, textarea, dropdown, number
- **Validation** — Backend validerar config.json schema vid upload
- **Fallback** — Om custom config är invalid/korrupt, använd default Steg 2-4 bara

3.17.5 Frontend Rendering

Frontend använder `wizardConfig` från POST `/riskfrågor/steg1` response för att dynamiskt rendera steg:

```

1 // RiskFrågorWizard.jsx
2 const { wizardConfig } = responseData;

```

```

3
4 {wizardConfig.steps.map((step, index) => (
5   <WizardStep
6     key={step.id}
7     stepNumber={step.id}
8     totalSteps={wizardConfig.totalSteps}
9     title={step.title}
10    questions={step.questions || DEFAULT_QUESTIONS[step.id]}
11    isCustom={step.isCustom}
12  />
13 )})}

```

3.18 Sammanfattning (Prosaisk beskrivning)

3.18.1 Scenario 1: Första gången - Inga riskflaggor

Aktörer:

- **Användare (inloggad):** Anna Andersson, redovisningskonsult på byrån (hennes `userId` i JWT token)
- **Presumtiv klient:** Celestial AB (org.nr 556903-8671), VD Bengt Bengtsson (personnr 196001011234)

Anna Andersson (redovisningskonsulten) sitter och intervjuar Bengt Bengtsson, VD för Celestial AB som vill bli kund. Anna har öppnat onboarding-appen och kommer från Uppdragsval-sliden med `onboardingId` sparat i `localStorage`.

På Riskfrågor Steg 1-sliden välkomnas hon med en intro-text om varför riskfrågor krävs (PTL-referens). Hon fyller i 9 grundfrågor baserat på information från Bengt:

1. **Affärsidé:** "Restaurang med mat från medelhavet"
2. **Kundtyper:** Privatpersoner OCH företag (både walk-in kunder och cateringuppdrag)
3. **Utländska partners:** "Nej"
4. **Leverantörer:** "Menigo, Martin & Servera, Systembolaget"
5. **Verksamhet ändrad:** "Nej"
6. **Organisationsnummer:** 556903-8671 (Celestial AB)
7. **Personnummer VD:** 196001011234 (Bengt Bengtsson)
8. **Verklig huvudman:** "Nej" (Bengt äger bara 15%, inte >25%)
9. **PEP-status:** Avmarkerad

När Anna klickar "Nästa" visas en loading spinner med text "Validerar uppgifter mot externa register...". Backend gör följande:

Steg 1-3: Autentisering och validering

- Extraherar `user_id` från JWT token (Anna Andersson's `userId` - redovisningskonsulten)
- Verifierar att `onboardingId` tillhör Anna (security check)
- Validerar format på org.nr (556903-8671) och personnr (196001011234)

Steg 4: Bolagsverket API-anrop

Backend anropar Bolagsverket POST `/organisationer` med org.nr 556903-8671 (klientens företag). Response innehåller:

```

1 {
2   "organisationsnummer": "556903-8671",
3   "namn": "Celestial AB",
4   "organisationsform": "AB",
5   "sniKod": "56101",
6   "sniBeskrivning": "Restauranger och gatukök",
7   "vd": {
8     "namn": "Bengt Bengtsson",
9     "personnummer": "196001011234"
10  },
11  "firmatecknare": [
12    {
13      "namn": "Bengt Bengtsson",
14      "personnummer": "196001011234"
15    }
16  ]
17 }

```

Backend verifierar att Bengt's personnummer (196001011234) matchar VD-personnumret från Bolagsverket. GODKÄND

Steg 5: SPAR API-anrop

Backend anropar Skatteverket SPAR POST /navet/spar/personnummer med personnummer 196001011234 (Bengt Bengtsson). Response innehåller:

```

1 {
2   "personnummer": "196001011234",
3   "namn": {
4     "fornamn": "Bengt",
5     "efternamn": "Bengtsson"
6   },
7   "folkbokforingsadress": {
8     "adress": "Storgatan 1",
9     "postnummer": "12345",
10    "postort": "Stockholm"
11  },
12  "status": "Folkbokförd"
13 }

```

Backend verifierar att Bengt är folkbokförd. GODKÄND

Steg 6-7: Roaring Beneficial Owners (två-steps algoritm)

Backend anropar först Roaring Primary Endpoint GET /beneficial-owners/2.1/556903-8671 (Celestial AB). Response innehåller:

```

1 {
2   "organizationNumber": "5569038671",
3   "companyName": "Celestial AB",
4   "beneficialOwners": [
5     {
6       "personalNumber": "197001011234",
7       "firstName": "Bengt",
8       "lastName": "Bengtsson",
9       "ownershipPercentage": 60.0,

```

```

10     "votingRightsPercentage": 60.0
11   },
12   {
13     "personalNumber": "196501011234",
14     "firstName": "Carl",
15     "lastName": "Carlsson",
16     "ownershipPercentage": 40.0,
17     "votingRightsPercentage": 40.0
18   }
19 ]
20 }

```

Två verkliga huvudmän identifierade (båda >25%). Backend behöver INTE anropa Alternative Endpoint eftersom primary gav resultat.

Steg 8: PEP/Sanctions/BusinessProhibition checks

För varje VH (Bengt och Carl) anropar backend:

- GET /pep/1.0/197001011234 → isPEP: false
- GET /sanctions/1.0/197001011234 → isSanctioned: false
- GET /businessprohibition/1.0/person/197001011234 → hasBusinessProhibition: false
- GET /pep/1.0/196501011234 → isPEP: false
- GET /sanctions/1.0/196501011234 → isSanctioned: false
- GET /businessprohibition/1.0/person/196501011234 → hasBusinessProhibition: false

Alla checks ger grönt ljus. INGA RED FLAGS

Steg 9: Beräkna riskAssessment (Celestial Risk Engine v3.0)

Komponent 1: Offentliga register (publicData)

- Bolagsålder: Celestial AB registrerat 2023-01-15 = 2 år → +4 poäng
- PEP-status: Ingen VH är PEP → 0 poäng
- Sanktioner: Ingen VH på sanktionslista → 0 poäng
- Näringsförbud: Ingen VH har näringsförbud → 0 poäng
- **Totalt publicData:** 4 poäng (av max 30)

Komponent 2: Korsvalidering (crossValidation)

- VH-mismatch: Klienten svarade "Nej" (ej VH) men Roaring visar Bengt som 60% ägare → Omvänd mismatch detekterad → +8 poäng
- Adressmismatch: SPAR visar Storgatan 1, Bolagsverket visar Storgatan 1 → 0 poäng
- F-skatt: (Kontrolleras ej i detta scenario) → 0 poäng
- Momsregistrering: (Kontrolleras ej i detta scenario) → 0 poäng
- **Totalt crossValidation:** 8 poäng (av max 30)

Komponent 3: Bokföringsdata (bookkeeping)

- Ännu ej analyserad i Steg 1 → 0 poäng (av max 40)

Beräkning:

$$\text{staticKycScore} = 4 + 8 + 0 = 12 \text{ poäng}$$

$$\text{sniHotFactor} = 3 \text{ (SNI 56101 = Restaurang, kontantintensiv)}$$

$$\text{hotBonus} = (3 - 1) \times 10 = 20 \text{ poäng}$$

$$\text{adjustedScore} = 12 + 20 = 32 \text{ poäng}$$

Riskklassificering:

- `adjustedScore = 32` → Inom intervall 0–40 → `riskLevel = "low"`
- Inga hårda triggers (sanctions/businessProhibition) → `requiresEDD = false`
- VH-mismatch detekterad → `requiresManualReview = true`

Steg 10: Beräkna triggers för UI-betoning

Backend sätter triggers baserat på klientens svar OCH API-resultat:

- `isPEP = false` (varken VD eller VH är PEP)
- `hasSanctions = false`
- `hasBusinessProhibition = false`
- `vhMismatch = true` (omvänd: klient säger nej men Roaring säger ja)
- `addressMismatch = false`
- `missingFTax = false`
- `missingVAT = false`
- `newCompany = false` (2 år gammalt)
- `highRiskIndustry = true` (SNI 56101 = restaurang)

OBS: Triggers används INTE för att hoppa över Steg 2-4. Steg 2-4 visas ALLTID (eller fler steg enligt `config.json`). Triggers används för att flagga risker och kan påverka vilka frågor som betonas, men wizard-stegen körs alltid igenom.

Steg 10-11: Spara i databas och returnera

Backend uppdaterar `onboarding_processes` tabell:

```
1 UPDATE onboarding_processes
2 SET
3   riskfragor_steg1 = '{...Bengts/Celestials_svar...}',
4   bolagsverket_data = '{...Celestial_AB_data...}',
5   spar_data = '{...Bengts_folkbokföringsdata...}',
6   beneficial_owners_data = '[[...Bengt...], [...Carl...]]',
7   triggers = '{"showUtlandska":false,"showKontanter":false,"
8     showVerksamhet":false,"showPEP":false}',
9   current_step = 2,
10  updated_at = NOW()
WHERE id = '550e8400-...' AND user_id = 'Anna_userId';
```

Backend sparar också alla 9 externa API-anrop i `external_api_responses` för audit trail.

Backend returnerar response:

```
1 {
2   "success": true,
3   "triggers": {"showUtlandska":false,"showKontanter":true,"
4     showVerksamhet":false,"showPEP":false},
5   "message": "Grundläggande riskbedömning klar - kontanthantering
6     flaggad",
7   "nextStep": "/riskfragor/steg2"
8 }
```

Frontend-hantering:

Frontend tar emot response, sparar triggers i `localStorage`, och navigerar ALLTID till `/riskfragor/steg2`. Frontend läser sedan `config.json` för att se vilka wizard-steg som ska

visas (minst Steg 2-4, eventuellt fler enligt användarens config.json). Triggers används för att flagga risker i backend och kan påverka vilka frågor som betonas i UI, men påverkar INTE om stegen visas eller inte.

OBS om databas: Under utveckling används CSV-filer för ALL databashantering (onboarding_processes.csv, external_api_responses.csv, etc.). PostgreSQL SQL införs FÖRST när hela applikationen fungerar felfritt som slutoptimering för att hantera fler simultana användare utan skrivfel/race conditions.

3.18.2 Scenario 2: Triggers aktiverade (högre risk)

Aktörer:

- **Användare (inloggad):** Anna Andersson, redovisningskonsult på byrån
- **Presumtiv klient:** TechStart AB, VD Eva Eriksson

Anna intervjuar Eva Eriksson, VD för TechStart AB som vill bli kund. Eva's företag har annorlunda profil än Celestial AB:

- **Kundtyper:** Privatpersoner OCH företag (högre risk)
- **Utländska partners:** "Ja, vi har kunder i Norge och Danmark" (gränsöverskridande verksamhet)

När backend beräknar triggers:

- `showUtlandska = true` (`utlandskaPartners !== "Nej"`)
- `showKontanter = true` (`kundTyper.privatpersoner = true`)

Backend returnerar:

```
1 {  
2   "success": true,  
3   "triggers": {"showUtlandska": true, "showKontanter": true, "  
               showVerksamhet": false, "showPEP": false},  
4   "message": "Riskflaggor identifierade (utländska transaktioner +  
               kontanter)",  
5   "nextStep": "/riskfragor/steg2"  
6 }
```

Frontend-hantering:

Precis som i Scenario 1, navigerar frontend ALLTID till `/riskfragor/steg2`. Skillnaden är att triggers nu är aktiva (`showUtlandska = true`, `showKontanter = true`), vilket kan användas för att:

- Betona specifika frågor i UI (t.ex. markera utländska transaktioner med varning)
- Visa extra hjälptext eller förklaringar för riskfyllda områden
- Flagga ärendet för manuell granskning i backend
- Påverka risk-score i slutlig bedömning

Frontend visar SAMMA wizard-steg (Steg 2-4) som i Scenario 1, men med triggers kan vissa frågor betonas eller flaggas för extra uppmärksamhet.

Steg 2-4 visas ALLTID (konfigurerbart via config.json):

1. **Steg 2 (Utländska transaktioner):** Vilka länder, omsättningsandel, fast driftställe

2. **Steg 3 (Kunder & Partners):** Återkommande partners, största leverantörer/kunder
3. **Steg 4 (Betalningar):** Betalningsmetoder, kontantandel, stora transaktioner

Efter att Anna besvarat Steg 2-4 (+ eventuella extra steg från config.json), sparas alla svar via POST /riskfragor/steg2 (en enda batch), och frontend navigerar till /identitetskontroll.

3.18.3 Scenario 3: Validering misslyckas - 403 Forbidden

Aktörer:

- **Användare (inloggad):** Anna Andersson, redovisningskonsult på byrån
- **Presumtiv klient:** Celestial AB (org.nr 556903-8671), VD Bengt Bengtsson
- **Person som försöker representera företaget:** David Davidsson (personnr 198001011234) - INTE behörig

Anna intervjuar David Davidsson som påstår sig vara VD för Celestial AB. Hon fyller i formuläret:

- **Organisationsnummer:** 556903-8671 (Celestial AB)
- **Personnummer VD:** 198001011234 (David Davidsson)

Backend anropar Bolagsverket och får response som visar att Bengt Bengtsson (INTE David) är VD:

```
1 {  
2   "vd": {  
3     "namn": "Bengt Bengtsson",  
4     "personnummer": "196001011234"  
5   },  
6   "firmatecknare": [  
7     {  
8       "namn": "Bengt Bengtsson",  
9       "personnummer": "196001011234"  
10    }  
11  ]  
12 }
```

Backend jämför det angivna personnumret (198001011234 - David) med VD och firmatecknare från Bolagsverket. INGEN MATCH hittas - David är inte behörig att representera företaget.

Backend returnerar:

```
1 {  
2   "success": false,  
3   "error": "not_authorized",  
4   "code": "PERSON_NOT_AUTHORIZED",  
5   "details": "Personnummer stämmer inte med VD/firmatecknare enligt  
6             Bolagsverket"  
7 }
```

Frontend visar error message i röd banner: "Du är inte behörig att skapa uppdrag för detta bolag. Endast VD och firmatecknare kan fortsätta."

3.18.4 Teknisk sammanfattning

Riskfrågor Steg 1 består av ett enda POST endpoint som tar emot 8 grundfrågor och gör omfattande validering mot externa API:er.

Externa anrop (total):

- 1× Bolagsverket (organisationer) — Validera org.nr + VD
- 1× SPAR (personnummer) — Validera VD personnummer
- 1-2× Roaring (beneficial-owners) — Hämta VH (primary + optional fallback)
- N× Roaring (PEP) — Kontrollera VD + VH mot PEP-listor (N = antal VH)
- N× Roaring (Sanctions) — Kontrollera VD + VH mot sanktionslistor
- N× Roaring (BusinessProhibition) — Kontrollera VD + VH mot näringsförbud

Svarstid: 3-5 sekunder beroende på antal VH och nätverkshastighet

Databas-operationer:

- 1× SELECT (verifiera ägarskap av onboardingId)
- 1× UPDATE (spara riskfrågor + triggers + externa API-data)
- 3-9× INSERT (logga alla externa API-anrop i external_api_responses)

Conditional routing:

- OM alla triggers = false → Nästa steg = /identitetskontroll (hoppa över Steg 2)
- OM minst en trigger = true → Nästa steg = /riskfrågor/steg2

Frontend uppdatering:

- Spara triggers i localStorage
- Spara bolagsverketData och sparData i localStorage (för visning)
- Uppdatera currentStep till 2
- Navigera till nextStep URL

Blockerande fel:

- Personnummer matchar inte VD/firmatecknare → 403 Forbidden
- Organisationsnummer finns inte → 404 Not Found
- Person är sanktionerad → 403 Forbidden (REJECT omedelbart)
- Person har näringsförbud → 403 Forbidden (REJECT omedelbart)

Icke-blockerande varningar:

- Person är PEP → Trigger showPEP = true (kräver fördjupning i Steg 2)
- Person ej folkbokförd → Varning till compliance-team (men fortsatt onboarding)
- Komplex ägarstruktur (totalCoverage < 50%) → Flagga för manuell granskning

4 SEKTION 2B: Riskfrågor – Steg 2 (Fördjupade frågor)

4.0.1 POST /api/onboarding/{onboardingId}/riskfrågor/steg2

Beskrivning:

Sparar fördjupade riskfrågor baserat på triggers från Steg 1. Endast frågor där trigger = true visas för användaren. Uppdaterar riskpoäng och beräknar om enhanced due diligence (EDD) krävs.

Request Headers:

```
1 {
2   "Authorization": "Bearer <access_token>",
3   "Content-Type": "application/json"
4 }
```

Request Body (Exempel - Alla triggers = true):

```
1 {
2   "utlandskaTransaktioner": {
3     "lander": "Norge , □ Danmark , □ Tyskland",
4     "andel": "20%",
5     "syfte": "Konsultuppdrag □ för □ nordiska □ kunder",
6     "valutor": "NOK , □ DKK , □ EUR"
7   },
8   "kontanthantering": {
9     "omfattning": "Sällan",
10    "maxBelopp": "5000 □ SEK",
11    "rutiner": "Kvitton □ sparas , □ bokförs □ samma □ dag"
12  },
13  "verksamhetsandring": {
14    "vad": "Lagt □ till □ online -kurser □ som □ ny □ intäktskälla",
15    "nar": "2024-06",
16    "varfor": "Efterfrågan □ från □ kunder"
17  },
18  "pepDetaljer": {
19    "befattning": "Före □ detta □ kommunalråd",
20    "period": "2015-2019",
21    "familjerelation": "Nej"
22  }
23 }
```

Request Body (Exempel - Endast utländska = true):

```
1 {
2   "utlandskaTransaktioner": {
3     "lander": "Norge , □ Danmark",
4     "andel": "10%",
5     "syfte": "Konsultuppdrag",
6     "valutor": "NOK , □ DKK"
7   }
8 }
```

Response (200 OK - Standard Risk):

```

1 {
2   "success": true,
3   "riskScore": 35,
4   "riskLevel": "STANDARD",
5   "eddRequired": false,
6   "message": "Standardrisk - ingen fördjupad granskning krävs. Du
7     kan gå vidare till identitetskontroll.",
8   "nextStep": "/identitetskontroll",
9   "riskFactors": [
10    {
11      "factor": "Utländska transaktioner",
12      "severity": "LOW",
13      "points": 15,
14      "reason": "Nordiska länder (lågriskländer), <25% av omsä
15        ttning"
16    },
17    {
18      "factor": "Kontanthantering",
19      "severity": "LOW",
20      "points": 10,
21      "reason": "Sällan, små belopp, goda rutiner"
22    },
23    {
24      "factor": "Verksamhetsändring",
25      "severity": "LOW",
26      "points": 10,
27      "reason": "Naturlig expansion, logisk förklaring"
28    }
29  ]
30 }

```

Response (200 OK - Enhanced Due Diligence Required):

```

1 {
2   "success": true,
3   "riskScore": 85,
4   "riskLevel": "HIGH",
5   "eddRequired": true,
6   "message": "Förhöjd risk - fördjupad due diligence krävs. Vi behö
7     ver granska fler dokument.",
8   "nextStep": "/identitetskontroll",
9   "riskFactors": [
10    {
11      "factor": "PEP-status",
12      "severity": "HIGH",
13      "points": 40,
14      "reason": "Politiskt exponerad person (före detta kommunalråd
15        )"
16    },
17    {
18      "factor": "Utländska transaktioner",
19      "severity": "MEDIUM",

```

```

18     "points": 25,
19     "reason": "Flera_länder,>10%_av_omsättning"
20 },
21 {
22     "factor": "Kontanthantering",
23     "severity": "MEDIUM",
24     "points": 20,
25     "reason": "Privatpersoner_som_kunder,kontanter_förekommer"
26 }
27 ],
28 "eddRequirements": [
29     "Specificera_källa_till_förmögenhet_för_PEP",
30     "Tillhandahåll_kontrakt_för_utländska_uppdrag",
31     "Dokumentera_kontanthanteringsrutiner_skriftligt",
32     "Förklara_relation_till_utländska_partners"
33 ]
34 }

```

Response (400 Bad Request):

```

1 {
2   "success": false,
3   "error": "Obligatoriska_fält_saknas",
4   "code": "MISSING_REQUIRED_FIELDS",
5   "details": {
6     "utländskaTransaktioner": "Detta_fält_är_obligatoriskt_när_
7       showUtländska=true",
8     "pepDetaljer": "Detta_fält_är_obligatoriskt_när_showPEP=true"
9   }
10 }

```

Response (403 Forbidden):

```

1 {
2   "success": false,
3   "error": "Onboarding-process_ägs_inte_av_inloggad_användare",
4   "code": "UNAUTHORIZED_ACCESS"
5 }

```

Business Logic:

1. Hämta user_id från JWT och verifiera ägarskap:

- SELECT från onboarding_processes WHERE id = onboardingId AND user_id = user_id_from_jwt
- Hämta triggers från Steg 1 (vilka frågor ska ställas)

2. Validera att endast relevanta fält är ifyllda:

- Om triggers.showUtländska = false → utländskaTransaktioner får INTE finnas
- Om triggers.showUtländska = true → utländskaTransaktioner MÅSTE finnas
- Samma logik för kontanthantering, verksamhetsändring, pepDetaljer

3. Beräkna riskpoäng (0-100):

- Utländska transaktioner:

- Lågriskländer (Norden, EU15) + <25% andel → 10-20 poäng (LOW)
- Medelriskländer (EU, OECD) + 25-50% andel → 20-35 poäng (MEDIUM)
- Högriskländer (FATF graylisting) + >50% andel → 40-60 poäng (HIGH)

- **Kontanthantering:**

- Sällan + <10,000 SEK + goda rutiner → 5-10 poäng (LOW)
- Ibland + 10,000-50,000 SEK + acceptabla rutiner → 15-25 poäng (MEDIUM)
- Ofta + >50,000 SEK + bristfälliga rutiner → 30-50 poäng (HIGH)

- **Verksamhetsändring:**

- Naturlig expansion + logisk förklaring → 5-10 poäng (LOW)
- Stor förändring + vag förklaring → 15-25 poäng (MEDIUM)
- Kompletta pivoting + ingen förklaring → 30-40 poäng (HIGH)

- **PEP-status:**

- Före detta (>2 år sedan) + lokal nivå → 30-40 poäng (HIGH)
- Nuvarande + lokal nivå → 50-60 poäng (HIGH)
- Nuvarande + nationell/internationell nivå → 70-90 poäng (CRITICAL)
- Familj till PEP → +20 poäng extra

4. Avgör risk level:

- 0-30 poäng → STANDARD (eddRequired = false)
- 31-60 poäng → MEDIUM (eddRequired = true, mild EDD)
- 61-100 poäng → HIGH (eddRequired = true, omfattande EDD)

5. Generera EDD-krav baserat på riskfaktorer

6. Uppdatera onboarding_processes:

- Spara riskfragor_steg2, risk_score, risk_level, edd_required
- Uppdatera current_step till 3 (identitetskontroll)

Databas:

```

1  -- Hamta triggers från Steg 1 för validering
2  SELECT
3      triggers,
4      riskfragor_steg1
5  FROM onboarding_processes
6  WHERE id = $1                                -- onboardingId (UUID)
7      AND user_id = $2;                        -- Fran JWT (security check)
8
9  -- Uppdatera med Steg 2 svar och riskbedömning
10 UPDATE onboarding_processes
11 SET
12     riskfragor_steg2 = $1::jsonb,
13     risk_score = $2,                          -- 0-100
14     risk_level = $3,                          -- STANDARD/MEDIUM/HIGH
15     edd_required = $4,                       -- boolean
16     risk_factors = $5::jsonb,                 -- Array av riskfaktorer
17     current_step = 3,
18     status = 'in_progress',
19     updated_at = NOW()
20 WHERE id = $6                                -- onboardingId (UUID)
21     AND user_id = $7;                        -- Fran JWT token (security check)

```

Database Schema (behövs i Loop 4):

```
1  -- Lagg till riskbedömning kolumner i onboarding_processes
2  ALTER TABLE onboarding_processes
3  ADD COLUMN IF NOT EXISTS riskfragor_steg2 JSONB,
4  ADD COLUMN IF NOT EXISTS risk_score INTEGER DEFAULT 0 CHECK (
5      risk_score >= 0 AND risk_score <= 100),
6  ADD COLUMN IF NOT EXISTS risk_level VARCHAR(20) CHECK (risk_level
7      IN ('STANDARD', 'MEDIUM', 'HIGH')),
8  ADD COLUMN IF NOT EXISTS edd_required BOOLEAN DEFAULT FALSE,
9  ADD COLUMN IF NOT EXISTS risk_factors JSONB DEFAULT '[]'::jsonb;
10
11 -- Index for risk-based queries
12 CREATE INDEX IF NOT EXISTS idx_onboarding_risk_level
13     ON onboarding_processes (risk_level);
14 CREATE INDEX IF NOT EXISTS idx_onboarding_edd_required
15     ON onboarding_processes (edd_required);
```

PTL-relevans:

- **PTL 2 kap 2 §:** Riskbaserad bedömning krävs
- **PTL 2 kap 8 §:** Förhöjd risk vid:
 - PEP (Politically Exposed Person)
 - Högriskländer enligt FATF
 - Ovanliga transaktionsmönster
 - Omfattande kontanthantering
- **PTL 3 kap 12-14 §§:** Enhanced Due Diligence (EDD) för högrisk
- **PTL 4 kap 3 §:** Transaktionsövervakning

5 SEKTION 3: Identitetskontroll

TODO: Dokumentera identitetskontroll och dokumentation

6 SEKTION 4: Jämförelse mot externa register

TODO: Dokumentera resultatslides från Bolagsverket/Roaring.io

7 SEKTION 5: Företagsdokumentation

TODO: Dokumentera dokumentuppladdning

8 SEKTION 6: Ekonomisk analys

TODO: Dokumentera SIE-fil, IBAN, Klarna Kosma integration

9 SEKTION 7: Djupgranskning och avtal

TODO: Dokumentera bokföringsanalys, riskbedömning, BankID-signering